

MÓDULO 3 · DOSSIER 12

Laboratorio: vulnerar contraseñas

El ataque offline revela la diferencia entre entropía humana, salt pública y costo de una KDF.

Material elaborado por el profesor Sergio Gevatschnaider

Fuente curricular verificable · SHA-256 be65a462a3ec

Contenido

Propósito	3
Resultados de aprendizaje	3
Núcleo teórico	3
Estrategias	3
Salt	3
KDF de contraseña	3
Cadena de ataque	3
Recomendaciones	3
Laboratorio seguro	4
Profundización y criterio profesional	4
Caso de análisis	4
Entrega esperada	4
Riesgos y errores frecuentes	4
Actividades de dominio	4
Lista de comprobación	5
Referencias seleccionadas	5

Propósito

El ataque offline revela la diferencia entre entropía humana, salt pública y costo de una KDF.

Resultados de aprendizaje

1. modelar un ataque offline.
2. medir diccionario, máscara y fuerza bruta acotada.
3. calibrar una KDF de contraseña.

Núcleo teórico

Una contraseña humana no es una clave uniforme. Un atacante offline puede probar candidatos sin consultar al servidor cuando posee:

- salt;
- parámetros;
- hash o clave derivada;
- información sobre hábitos humanos.

Estrategias

- diccionario;
- reglas y sustituciones;
- palabras + años;
- máscaras;
- PIN;
- fuerza bruta acotada.

Salt

La salt es pública, única y aleatoria. Evita precálculo compartido y hashes idénticos entre usuarios, pero no impide probar candidatos.

KDF de contraseña

PBKDF2, bcrypt, scrypt o Argon2id elevan el costo de cada intento. No crean entropía inexistente. Argon2id combina resistencia a ataques dependientes e independientes de datos y permite ajustar memoria, iteraciones y paralelismo.

Los perfiles de RFC 9106 sirven como punto de referencia, no como valores universales. La aplicación debe medir su plataforma, fijar un tiempo aceptable para autenticación legítima, reservar memoria compatible con concurrencia, almacenar los parámetros junto al verificador y poder actualizarlos. NIST SP 800-63B-4 recomienda un esquema resistente a ataques offline, salt y factor de costo apropiado.

Cadena de ataque

```
candidato
-> normalización y codificación
-> KDF con la misma salt y parámetros
-> comparación con objetivo
```

Recomendaciones

- Argon2id cuando sea posible;

- parámetros actualizables;
- salts únicas;
- gestor de contraseñas;
- MFA;
- límites y detección para ataques online;
- protección adicional de secretos de servidor cuando corresponda.

Laboratorio seguro

El laboratorio del módulo opera con contraseñas ficticias, espacio de búsqueda acotado y ejecución local. El objetivo es medir cómo cambian intentos y tiempo, no recuperar credenciales reales. Un ejercicio correcto debe:

1. generar una salt distinta por registro;
2. guardar algoritmo, parámetros, salt y verificador;
3. probar un diccionario didáctico limitado;
4. comparar candidatos con el mismo procedimiento;
5. documentar por qué el costo no reemplaza una contraseña fuerte;
6. terminar sin exportar datos ni conectarse a servicios externos.

Profundización y criterio profesional

Cuando un atacante obtiene salt, parámetros y verificador puede probar candidatos sin bloqueos del servidor. La salt evita precálculo compartido y verificadores iguales entre usuarios; no impide probar cada candidato. Una KDF costosa multiplica tiempo y memoria por intento, pero no crea entropía.

Argon2id permite ajustar memoria, iteraciones y paralelismo. RFC 9106 ofrece perfiles de referencia; la aplicación debe medir su plataforma, contemplar concurrencia, almacenar parámetros y admitir actualización. PBKDF2 puede ser necesario por compatibilidad, pero su costo es principalmente computacional.

El laboratorio seguro utiliza identidades y contraseñas ficticias, un espacio acotado, ejecución local y ausencia de exportación. No se prueba contra cuentas ni datos reales.

Caso de análisis

Compare una contraseña humana predecible bajo un hash rápido y bajo Argon2id. Analice tasa de intentos, memoria, salt, pepper opcional, MFA y estrategia de actualización al iniciar sesión.

Entrega esperada

Documento activos, actores, propiedad, parámetros, flujo, condición de fallo y decisión recomendada. Separe siempre la garantía criptográfica de la garantía operativa.

Riesgos y errores frecuentes

- atacar credenciales reales.
- usar SHA-256 directo para almacenamiento.
- copiar parámetros sin medir la plataforma.

Actividades de dominio

1. ¿Por qué la salt no es secreta?

2. ¿Qué diferencia hay entre ataque online y offline?
3. ¿Cómo se migran parámetros sin conocer la contraseña?

Lista de comprobación

- Puedo definir la propiedad y el adversario.
- Puedo explicar parámetros, límites y supuestos.
- Puedo detectar al menos tres configuraciones inseguras.
- Puedo justificar una decisión de arquitectura.
- Puedo relacionar el tema con una norma o especificación primaria.

Referencias seleccionadas

1. RFC 9106: Argon2 - <https://www.rfc-editor.org/rfc/rfc9106>
2. NIST SP 800-63B-4 - <https://doi.org/10.6028/NIST.SP.800-63B-4>